

■■ CYBERSHIELD

Software Design Document

Document CS-SDD-002 — Version 1.0

CS-SDD-002 · v1.0 · 28/05/2026 · CONFIDENTIAL

Francisco José Jiménez Pozo · fjjpozo075@gmail.com | github.com/franjmenezz

1. Document Information

Document	Software Design Document
Reference	CS-SDD-002
Version	1.0
Date	28/05/2026
Author	Francisco José Jiménez Pozo
Based on	CS-SRS-001 v1.0

2. System Architecture

2.1 Data Models

Model	ODOO Table	Responsibility
cyber.device	cyber_device	Endpoint inventory, Zero Trust agent tokens, risk scoring, status tracking
cyber.log	cyber_log	IMMUTABLE security events with HMAC-SHA256 hash chaining (write/delete forbidden)
cyber.alert	cyber_alert	Risk-classified alerts with SLA tracking, MITRE mapping and full lifecycle management
cyber.vulnerability	cyber_vulnerability	CVE tracking with CVSS scoring (auto-computed from score) per asset
cyber.incident	cyber_incident	Full incident lifecycle aligned with ISO 27035, RGPD notification tracking
cyber.report	cyber_report	Audit report generation with approval workflow
cyber.notification.channel	cyber_notification_channel	Notification channels: ODOO internal, email, generic webhook (Telegram/Slack/etc.)
cyber.escalation.rule	cyber_escalation_rule	Configurable escalation rules with severity filters, delay and repeat settings
cyber.notification	cyber_notification	Full notification history with delivery status, error details and retry support

2.2 RBAC Security Matrix

Role	Devices	Logs	Alerts	Incidents	Reports	Notif.	Config
Admin	Full	Full	Full	Full	Full	Full	Full
Sr. Analyst	R/W	Read	Full	Full	Full	Read	None
Analyst	Read	Read	R/W	R/W	None	Read	None
Auditor	Read	Read	Read	Read	R/W	Read	None
Read Only	Read	None	Read	None	None	None	None

3. API Design

3.1 Security Model

- Authentication: Agent token in X-CyberShield-Token header
- Integrity: HMAC-SHA256 signature of request body in X-CyberShield-Signature header
- Rate limiting: 1,000 events per 60-second sliding window per agent token
- Input validation: all fields sanitised, enum values validated against whitelist
- Zero Trust: every request independently authenticated regardless of source IP

3.2 Endpoints

Method	Path	Auth	Description
GET	/cybershield/api/v1/health	None	Health check — returns system status
POST	/cybershield/api/v1/event	Token + HMAC	Ingest a security event from a Wazuh agent
GET	/cybershield/api/v1/device	Token	Get device info for the authenticated agent

4. Key Security Design Decisions

4.1 Immutable Audit Logs

The `cyber.log` model overrides `write()` and `unlink()` methods from ODOO ORM, raising `AccessError` on any modification or deletion attempt. This is enforced at the Python level — impossible to bypass through UI, API or direct ORM calls. The only insertion path is the authenticated API endpoint.

4.2 HMAC-SHA256 Hash Chaining

Each log entry hash includes the previous entry hash as part of a canonical JSON payload (sorted keys for determinism). This creates a tamper-evident chain — modifying any historical record invalidates all subsequent hashes, making tampering immediately detectable via the `Verify Integrity` function.

4.3 Zero Trust Device Authentication

Each device has a unique agent token generated using UUID4 salt + SHA-256. Tokens are only visible to CyberShield Administrators. The API verifies both token (identity) and HMAC signature (request integrity) on every single request — no session state, no implicit trust.

4.4 Notification Channel Abstraction

The Notification Center uses a channel abstraction layer that decouples the notification engine from any external service. Webhook channels accept any HTTP endpoint — Telegram, Slack, Teams, or custom servers. The module itself has zero dependency on any third-party notification service.